Guion de presentación · Cuidarte+

Verificando la calidad, seguridad y cumplimiento normativo
Caso B · Sistema de exámenes médicos Cuidarte+

ISY1102 Seguridad y Calidad en el Desarrollo de Software
Duoc UC · Sede Puente Alto · Sección 001V
Evaluación Parcial 4 · Presentación
Docente Jose Sergio Collio Huennun

Integrantes
Ari Araya
Nicolás Barra
Giannina Guerrero
Skarlett Tropan

27 de octubre de 2026
19:01 · Sala LC8

Tiempos

Tenemos 10 minutos para exponer y 5 para preguntas. Giannina, Ari y Nicolás hablan 2 minutos y 25 segundos cada uno, y Skarlett 2 minutos y 30 segundos porque suma CP-17 en la lámina 08. El guion termina en el minuto 9:45 y deja 15 segundos de margen. Los tiempos están calculados a ritmo de conversación, unas 150 palabras por minuto. En la lámina 07, Ari muestra sus resultados con las capturas de CP-15 y CP-05 del deck. Si en el ensayo alguien se pasa, recorta su propio texto; el margen no se reparte.

Integrante	Láminas	Tiempo
Giannina Guerrero	01, 06, 09b, 10	2:25
Ari Araya	02, 03, 07b, 11	2:25
Nicolás Barra	04, 07a	2:25
Skarlett Tropan	05, 08, 09a	2:30
Total	01 a 12	9:45

Lámina	Tema	Habla	Tiempo	Reloj
01	Portada	Giannina	0:30	0:00 a 0:30
02	Contexto	Ari	0:30	0:30 a 1:00
03	Objetivo	Ari	0:15	1:00 a 1:15
04	Estrategia	Nicolás	0:55	1:15 a 2:10
05	Tipos de prueba	Skarlett	0:55	2:10 a 3:05
06	Cobertura	Giannina	0:35	3:05 a 3:40
07a	Hallazgos (primera parte)	Nicolás	1:30	3:40 a 5:10
07b	Hallazgos (segunda parte)	Ari	1:15	5:10 a 6:25
08	SonarQube frente a la ley	Skarlett	1:15	6:25 a 7:40
09a	Normativa (primera parte)	Skarlett	0:20	7:40 a 8:00
09b	Normativa (segunda parte)	Giannina	0:20	8:00 a 8:20
10	Dictamen	Giannina	1:00	8:20 a 9:20
11	Cierre	Ari	0:25	9:20 a 9:45
	Margen		0:15	9:45 a 10:00

Estructura de la exposición

La exposición sigue cuatro ejes: riesgo, evidencia, norma y recomendación. Cada sección cierra con una transición formal que anuncia la siguiente y quién la presenta.

- Planificación y trazabilidad. Giannina presenta el propósito, Ari el sistema y la pregunta central, Nicolás la estrategia, Skarlett los tipos de prueba y Giannina la matriz.
- Ejecución funcional. Nicolás presenta CP-07, CP-03 y los controles efectivos.
- Seguridad dinámica. Ari presenta la clasificación de defectos y la evidencia de ZAP, curl, John the Ripper y JMeter.
- Análisis estático y controles. Skarlett presenta SonarQube y la configuración frente a la ley.
- Análisis normativo y dictamen. Giannina presenta el marco legal, el dictamen y tres recomendaciones.
- Conclusión. Ari sintetiza los resultados y cierra.

Antes de partir

- Deck abierto en pantalla completa con la tecla F. Las flechas avanzan y retroceden.
- En las láminas 07 y 08 las capturas se agrandan con un clic y se cierran con Esc.
- Ari tiene a mano su evidencia de ZAP, John the Ripper y JMeter por si piden más detalle.
- Quien habla maneja el control. Alguien del grupo lleva el cronómetro a la vista.
- La nota es individual. Cada uno tiene que poder explicar cualquier lámina, no solo la suya.

Lámina 01 · Portada · presentación

Habla	Tiempo	Reloj
Giannina Guerrero	0:30	0:00 a 0:30

En pantalla

- Deck en pantalla completa (tecla F) antes de partir.
- Giannina habla mirando al curso, sin leer la lámina.

Qué decir

> Buenas tardes. Presentamos la verificación de calidad, seguridad y cumplimiento normativo de Cuidarte+, el sistema de exámenes médicos del caso B. El análisis sigue cuatro ejes: el riesgo de cada componente, la evidencia obtenida en la ejecución, la norma aplicable y la recomendación que se deriva de ella.
>
> Los integrantes son Ari Araya, Nicolás Barra, Skarlett Tropan y Giannina Guerrero.
>
> **Pase a Ari. «A continuación, Ari presenta el sistema y dónde se almacenan los datos clínicos.»**

Lámina 02 · Contexto · dónde residen los datos

Habla	Tiempo	Reloj
Ari Araya	0:30	0:30 a 1:00

En pantalla

- Recorrer la franja de arquitectura de izquierda a derecha (React, API, PostgreSQL).
- Apuntar a los tres roles y terminar en la tarjeta Dato sensible.

Qué decir

> Gracias. Cuidarte+ tiene tres capas. El usuario accede a una aplicación React que consume una API en Express, la cual persiste en PostgreSQL. Levanté el ambiente de pruebas en Docker local, con un contenedor por capa.
>
> Hay tres roles. El médico registra pacientes y exámenes, el administrador gestiona usuarios y auditoría, y el paciente solo debe acceder a su propia información. Los exámenes forman parte de la ficha clínica, que la Ley 20.584 califica como dato sensible.
>
> **Sigue Ari con la lámina 03, sin pausa.**

Lámina 03 · Objetivo · pregunta central

Habla	Tiempo	Reloj
Ari Araya	0:15	1:00 a 1:15

En pantalla

- Apuntar a la pregunta central y recorrer los cinco objetivos, de izquierda a derecha.

Qué decir

> La pregunta central es si Cuidarte+ está en condiciones de pasar a producción. Para responderla definimos cinco objetivos. Trazar, ejecutar, clasificar, contrastar con la normativa y recomendar. La ejecución se cerró el 26 de octubre y la revisión de código, el 27.
>
> **Pase a Nicolás. «Planteado el objetivo, Nicolás expone la estrategia con que abordamos el riesgo.»**

Lámina 04 · Estrategia · planificación

Habla	Tiempo	Reloj
Nicolás Barra	0:55	1:15 a 2:10

En pantalla

- Apuntar primero a Automatizado y Manual.
- Detenerse en la frase destacada sobre la interfaz y la API.
- Señalar P0 y terminar en la línea de tiempo inferior.

Qué decir

> La estrategia es mixta. Automatizamos lo repetible o medible, con JMeter, ZAP, SQLMap, SonarQube y Selenium. Con Selenium armamos una suite de 11 pruebas de interfaz que el 27 de octubre pasó completa, y recorre login, logout, pacientes, exámenes, permisos por rol y Mis Resultados. Lo que requiere criterio queda manual, como la usabilidad para personas mayores, TLS y respaldos. La seguridad y la normativa entraron desde el diseño, porque son datos de salud.
>
> Adoptamos además un criterio de verificación. La interfaz no constituye evidencia suficiente. El control de acceso se comprueba en la respuesta de la API y en la tabla de auditoría. Priorizamos por riesgo, de P0 a P4. P0 agrupa autenticación, control de acceso y documentos clínicos, es decir, los controles que protegen la ficha clínica. La secuencia fue preparación, diseño, prueba de humo, ejecución y cierre.
>
> **Pase a Skarlett.** *«Definida la estrategia, Skarlett explica los tipos de prueba aplicados y su fundamento.»*

Lámina 05 · Tipos de prueba · origen e impacto

Habla	Tiempo	Reloj
Skarlett Tropan	0:55	2:10 a 3:05

En pantalla

- Recorrer las tarjetas en orden, señalando en cada una Origen e Impacto.
- Al referirse a usabilidad, apuntar a la tarjeta 07.

Qué decir

> Cada tipo de prueba responde a un requisito del ERS y a un impacto sobre el usuario. Las pruebas funcionales derivan de los RF y verifican que el paciente pueda consultar su examen. Las de API revisan lo que ocurre detrás de la interfaz, como tokens y códigos HTTP.
>
> La seguridad dinámica deriva de los NFR de seguridad y de RB-1, y su impacto es el acceso indebido a la ficha. El análisis estático busca secretos y dependencias vulnerables en el código. El rendimiento deriva del umbral de 300 milisegundos, y su impacto es un acceso tardío al examen.
>
> La usabilidad la ejecuté en CP-06. Lighthouse obtuvo 0,96 en accesibilidad, pero el texto del botón Entrar presenta un contraste de 3,98 a 1, inferior al mínimo de 4,5. Para una persona mayor, esto puede impedir el acceso a sus resultados.
>
> **Pase a Giannina.** *«Definidos los tipos de prueba, Giannina presenta la trazabilidad con el ERS.»*

Lámina 06 · Cobertura · trazabilidad

Habla	Tiempo	Reloj
Giannina Guerrero	0:35	3:05 a 3:40

En pantalla

- Apuntar al 14 y luego al 40.
- Apuntar a la barra de resultados 10, 10, 18 y 2.

Qué decir

> Los 40 códigos del ERS B definen los requisitos que el sistema debe cumplir. En la EV1 la matriz cubría 14 y dejaba 21 sin caso. La reconstruí, y hoy los 40 tienen caso, tipo, riesgo y responsable.
>
> Sin embargo, la cobertura de diseño no equivale a cumplimiento. Hoy 38 de los 40 tienen resultado, con 10 aprobados, 10 parciales y 18 fallidos. Los 2 sin ejecutar son de rendimiento y dependen de CP-19, que al 27 de octubre no se ha corrido. RB-3 se probó tal como está escrita y quedó como observación OC-01 frente a la Ley 20.584.
>
> **Pase a Nicolás. «Establecida la trazabilidad, Nicolás presenta la evidencia de la ejecución funcional.»**

Lámina 07a · Hallazgos (primera parte) · ejecución funcional

Habla	Tiempo	Reloj
Nicolás Barra	1:30	3:40 a 5:10

En pantalla

- Clic en la captura de CP-07 para agrandarla. Esc para cerrar.
- Clic en la captura de CP-03 para agrandarla. Esc para cerrar.
- Al final, apuntar a la tarjeta verde Controles OK.

Qué decir

> La ejecución funcional y de API se realizó el 20 de octubre y quedó registrada en la bitácora con su evidencia. Ese día se confirmaron cinco incidentes. Presento los dos de mayor riesgo para la confidencialidad de la ficha clínica.

Clic en la captura de CP-07.

> CP-07 verifica el cierre de sesión. Se obtiene un token, se cierra sesión y la interfaz vuelve al login. Sin embargo, el mismo token enviado a la API sigue respondiendo 200. No existe revocación y el token dura dos horas. Corresponde a INC-03, de severidad grave, en un caso P0. A esto se suma INC-02, el secreto JWT publicado en el repositorio.

Esc. Clic en la captura de CP-03.

> CP-03 verifica la auditoría. La subida de documentos queda registrada, pero la descarga no. Corresponde a INC-13. Además, con token de médico fue posible crear un registro arbitrario en la auditoría, con respuesta 201, lo que corresponde a INC-14.

Esc.

> Según el código, la ruta /roles permite crear, editar y eliminar roles sin token. Es INC-07. Skarlett lo confirmó en el código el 27 de octubre, pero CP-08 no alcanzó a invocar la ruta, así que no tiene prueba dinámica. También se registraron controles efectivos. SQLMap no detectó inyección en el login y la carga OR 1=1 responde 401. El médico recibe 403 en /usuarios y el paciente solo accede a sus propios exámenes. La parte dinámica de CP-04 la presenta Ari a continuación.

Pase a Ari. «Presentada la evidencia funcional, Ari expone la seguridad dinámica.»

Lámina 07b · Hallazgos (segunda parte) · seguridad dinámica

Habla	Tiempo	Reloj
Ari Araya	1:15	5:10 a 6:25

En pantalla

- Apuntar a la tarjeta roja INC-01 Crítico.
- Clic en la captura de CP-15 para agrandarla. Esc para cerrar.
- Apuntar a la tarjeta INC-05 y a Controles OK.

- Clic en la captura de CP-05. Esc para cerrar.

Qué decir

> Clasificamos los defectos en cuatro niveles según el dato afectado. Con la ejecución del 26 de octubre y la revisión de Skarlett del 27 quedaron 1 crítico, 9 graves y 7 moderados, sin leves. INC-01 es el único crítico y CP-15 lo confirmó. Las contraseñas se guardan en texto plano.

Clic en la captura de CP-15.

> John the Ripper respondió que no había hashes que cargar, porque no hay nada que romper. Quien acceda a la base obtiene las claves de todos los usuarios.

Esc.

> En la EV1, ZAP se ejecutó sin sesión. Ahora lo corrí autenticado, con token de médico y de paciente, y terminó sin alertas altas, con 2 medias y 4 bajas. Con curl confirmé el CORS abierto y la falta de cabeceras de seguridad, que es INC-05, moderado. Con token de paciente, pedir los exámenes de otro paciente o intentar escribir responde 403, así que RB-1 se cumple.

Clic en la captura de CP-05.

> En rendimiento, JMeter midió consultas de cinco segundos frente a los 300 milisegundos del ERS, por el retraso escrito en el código. Es INC-04, grave. La corrida sin retraso y CP-19 quedaron sin ejecutar.

Esc.

Pase a Skarlett. *«Expuesta la evidencia dinámica, Skarlett presenta el análisis estático y su lectura normativa.»*

Lámina 08 · SonarQube frente a la ley · análisis estático

Habla	Tiempo	Reloj
Skarlett Tropan	1:15	6:25 a 7:40

En pantalla

- Clic en la captura del resumen de SonarQube backend. Esc para cerrar.
- Apuntar a las métricas de la derecha.
- Recorrer la tabla de la izquierda fila por fila, de la regla al deber legal.
- Detenerse en la fila Mensaje interno en errores 500 al hablar de CP-17.

Qué decir

> Ejecuté SonarQube el 20 de octubre sobre backend y frontend.

Clic en la captura del resumen de backend. Esc.

> El Quality Gate resultó Passed, pero esa condición evalúa solo el código nuevo. Sobre el código total, el backend presenta 4 vulnerabilidades y calificación E en

seguridad, y el frontend 14 bugs. La cobertura es cero, porque no existen pruebas unitarias.

Frente a la normativa, SonarQube clasificó como Blocker la contraseña de PostgreSQL escrita en el código, lo que contraviene el deber de cuidado del artículo 11 de la Ley 19.628. También detectó el CORS permisivo, que leemos con el artículo 8 del DS 41. No detectó el secreto JWT repetido en siete rutas, y el análisis de dependencias se omitió. Tampoco ve la lógica de negocio, como el texto plano o la descarga sin auditoría.

Sonar tampoco marcó los mensajes internos de los errores, así que el 27 de octubre cerré CP-17 revisando el código. Encontré 34 bloques catch que le devuelven err.message al cliente. CP-17 queda fallido, con INC-06 confirmado en el código e INC-14 confirmado en CP-03. Por eso el análisis estático no reemplaza a las pruebas dinámicas.

Sigue Skarlett con la lámina 09a, sin pausa.

Lámina 09a · Normativa (primera parte) · controles de configuración

Habla	Tiempo	Reloj
Skarlett Tropan	0:20	7:40 a 8:00

En pantalla

- Apuntar a la tarjeta DS 41.

Qué decir

En configuración, CP-14 muestra que no hay TLS, y CP-16, que los datos clínicos no tienen cifrado en reposo. CP-18 confirma que la restauración manual funciona, pero sin política de programación, retención ni copia externa. Estos resultados incumplen el artículo 8 del DS 41.

Pase a Giannina. «Contrastada esta evidencia con la configuración, Giannina presenta el marco normativo.»

Lámina 09b · Normativa (segunda parte) · análisis normativo

Habla	Tiempo	Reloj
Giannina Guerrero	0:20	8:00 a 8:20

En pantalla

- Apuntar a la línea de tiempo superior, en el 01-12-2026.
- Apuntar a las tarjetas 20.584 y DS 41.

Qué decir

Estas normas obligan principalmente al centro de salud, pero si el sistema no permite cumplirlas, el centro tampoco podrá hacerlo. El eje del análisis son la Ley 20.584 y el DS 41, ambos vigentes. La Ley 21.719 entrará en vigencia el 1 de diciembre, en cinco semanas.

Sigue Giannina con la lámina 10, sin pausa.

Lámina 10 · Dictamen · recomendaciones

Habla	Tiempo	Reloj
Giannina Guerrero	1:00	8:20 a 9:20

En pantalla

- Apuntar al sello No certificado.
- Apuntar al recuadro Hacia Certificado con reservas.
- Al defender las tres recomendaciones, apuntar a las tarjetas 01, 02 y 03 en ese orden.

Qué decir

> Con esta evidencia, el dictamen es No certificado, y lo sostienen tres incidentes. El primero es INC-01, el único crítico, las contraseñas en texto plano que CP-15 confirmó. Le siguen dos graves que están en el código, INC-02, el secreto JWT publicado, e INC-07, la ruta /roles que no pide token. Además fallaron cuatro casos P0, CP-15, CP-07, CP-14 y CP-16, y también CP-17 y CP-23, mi revisión normativa. Para llegar a Certificado con reservas hay que cerrar esos tres, lograr que pasen los P0 y fechar INC-04 e INC-13.
>
> Propongo tres recomendaciones, una por incidente. Primero, hash con bcrypt y contraseñas de 12 caracteres, por el deber de cuidado del artículo 11 de la Ley 19.628. Segundo, rotar el secreto JWT y que el cierre de sesión revoque el token. Tercero, exigir token y control de rol en /roles, porque el artículo 13 de la Ley 20.584 restringe el acceso a quienes participan en la atención.

Pase a Ari. «Definidas la norma y las recomendaciones, Ari presenta la conclusión.»

Lámina 11 · Cierre · conclusión

Habla	Tiempo	Reloj
Ari Araya	0:25	9:20 a 9:45

En pantalla

- Apuntar a la frase central del cierre.
- Al agradecer, avanzar a la lámina de Preguntas.

Qué decir

> Para concluir, el riesgo se concentra en el control de acceso y en el resguardo de credenciales, y la evidencia lo confirma en la API y en el código. La normativa exige ese resguardo, y las tres recomendaciones definen el camino hacia la certificación. Todas las pruebas se realizaron con datos sintéticos y en nuestro ambiente local, conforme a la Ley 21.459 de delitos informáticos.
>
> *Avanzar a la lámina 12.*

> Muchas gracias. Quedamos atentos a sus preguntas.
>
> **Se abre la ronda de preguntas.**

Preguntas probables

Dos por integrante, con respuesta breve de quien corresponda y basada solo en datos del informe.

Giannina Guerrero

Si faltan 2 códigos por ejecutar, ¿no es prematuro emitir un dictamen No certificado?

No, porque lo que falta no altera el resultado. Para certificar se requiere que no haya críticos abiertos, que todos los casos P0 estén aprobados y que los 40 códigos tengan resultado. Hoy no se cumple ninguna de esas condiciones. Lo que falta modifica el plan de corrección, no el dictamen.

¿Por qué el dictamen se apoya en INC-02 e INC-07 si no tienen prueba dinámica?

Porque el dictamen ya queda cerrado con INC-01 confirmado y los cuatro P0 fallidos. INC-02 e INC-07 se suman porque el defecto está a la vista en el código. El secreto JWT aparece en el README y /roles no pide token. Después de las contraseñas, son los que más exponen la ficha. La prueba dinámica de los dos quedó en el plan.

¿Qué conflicto presenta RB-3 con la normativa?

RB-3 permite que cualquier médico acceda a la información de cualquier paciente, mientras que el artículo 13 de la Ley 20.584 restringe el acceso a quienes participan en la atención. La probamos como está escrita y la registramos como observación OC-01. Proponemos limitar el acceso a los pacientes atendidos, con un acceso de emergencia registrado conforme al artículo 15 b). Es una decisión que corresponde al cliente.

Nicolás Barra

¿Usaron Selenium o no?

Sí. El 27 de octubre ejecuté una suite de 11 pruebas con pytest y Page Objects en Chrome, y pasaron las 11. Cubre el login válido e inválido, el logout, pacientes, exámenes, el acceso por rol a usuarios y Mis Resultados del paciente, y cada prueba deja su captura y un reporte. Selenium valida lo que se ve en pantalla. Por eso CP-07 sigue fallido, ya que la interfaz vuelve al login pero el token sigue válido en la API.

Si la interfaz vuelve al login, ¿cómo se demuestra que la sesión no se cerró?

Guardé el token antes del cierre de sesión y luego lo envié nuevamente a GET /examenes. La API respondió 200. Swagger tampoco expone un endpoint de logout. La interfaz cambia, pero el servidor sigue aceptando el token, y por eso la evidencia se toma de la API.

SQLMap no detectó inyección. ¿CP-04 queda aprobado?

No, queda parcial. SQLMap se ejecutó sobre el login y no encontró parámetros inyectables, y las cargas OR 1=1 respondieron 401. Ari corrió ZAP autenticado sin alertas altas y probó el control de acceso con curl, pero el CORS abierto y la falta de cabeceras confirman INC-05, y Burp y Nikto no se usaron. Por eso no corresponde aprobarlo.

Skarlett Tropan

Si el Quality Gate resultó Passed, ¿por qué se informan deficiencias?

Porque el Quality Gate evalúa el código nuevo, y en el primer análisis el código heredado lo aprueba igualmente. Sobre el código total, el backend presenta 4 vulnerabilidades y calificación E en seguridad, el frontend 14 bugs, y la cobertura es cero por ciento.

¿Cómo se verificó TLS sin un ambiente de producción?

Mediante la configuración del despliegue y solicitudes con curl. Frontend y API respondieron 200 por HTTP, la conexión HTTPS falló, no existe HSTS y PostgreSQL tiene ssl desactivado. Nikto no estaba instalado en mi equipo, así que CP-14 quedó fallido con curl y la revisión de la configuración, y esa limitación quedó declarada en el informe.

¿Por qué CP-17 queda fallido si no hay captura de un error 500?

Porque el defecto está en el código. Revisé las 8 rutas y 34 bloques catch devuelven err.message, así que cualquier error de la base llega al cliente con su mensaje interno. La captura de un 500 real no la tenemos y eso quedó declarado en el informe.

¿Por qué INC-14 e INC-16 suben a grave?

Por el dato afectado. INC-14 permite escribir registros falsos en la auditoría, que el artículo 9 del DS 41 exige confiable. INC-16 deja documentos clínicos en una ruta pública sin token. INC-15 pasa de leve a moderado porque el ERS exige aceptar DOC y PPT.

Ari Araya

¿Por qué INC-01 se clasifica como crítico si el sistema sigue operando?

Porque la severidad la determina el dato afectado. Con contraseñas en texto plano, quien acceda a la base obtiene las credenciales de todos los usuarios y, con ellas, acceso a la ficha clínica. La continuidad del servicio no reduce ese riesgo. El hallazgo ya se observó en la EV1, y en CP-15 la base de prueba mostró las claves sin hash.

¿Por qué no se midió el sistema sin el retraso de cinco segundos?

Estaba planificado, pero no alcanzó a correrse. El retraso está escrito en el código y con él toda medición incumple los 300 milisegundos, como mostró CP-05 con consultas de cinco segundos. Por eso NFR-PERF-1 queda fallido, y NFR-PERF-2 y NFR-PERF-3 quedan sin ejecutar junto con CP-19.

Nota para Ari · lo que sigue sin ejecutar

Los resultados del 26 de octubre ya están en el guion. Esto es lo único que queda sin ejecutar.

- CP-13, tiempo de descarga de un documento frente a los 10 segundos. No se midió y RF-4.2 queda parcial.
- CP-19, Lighthouse sobre la página principal y JMeter con 200 usuarios. No se ejecutó, y NFR-PERF-2 y NFR-PERF-3 quedan sin ejecutar.
- Burp y Nikto no se corrieron. Si lo preguntan, decirlo así y explicar que el control de acceso se probó con Swagger y curl y las cabeceras con curl.
- Si alcanzas a correr algo antes de la presentación, avisar a Giannina para ajustar el conteo de 38 de 40.